Device Provisioning Policy

The Grand Marina Hotel — Water Monitoring System

Field	Detail
Document Version	1.1
Created By	Emad Samara
Date	September 28, 2026
Approved By	

1. Scope and Purpose

This policy governs the provisioning, management, and decommissioning of HYDROLOGIC devices connected to The Grand Marina Hotel's water monitoring system.

Devices Covered

Device ID	Location	Certificate	Status
HYDROLOGIC-MainBuilding-001	Mechanical Room A	device-001.pem	Active
HYDROLOGIC-PoolSpa-002	Pool Pump House	device-002.pem	Active
HYDROLOGIC-Kitchen-003	Kitchen Mechanical	device-003.pem	Active
[Future devices as deployed]	—	—	—

2. New Device Onboarding Process

Step 1: Device Registration

Register the device's serial number in two places: (a) the HYDROLOGIC Device Registry, which maps each device ID to its certificate, location, and owner; and (b) the hotel's asset inventory, so the device is covered by the hotel's own audits. Assign a device ID using the pattern HYDROLOGIC-[Location]-[NNN], where the number is the next sequential three-digit number (for example, HYDROLOGIC-Laundry-004). Before continuing, confirm the ID does not already exist in either system.

Step 2: Certificate Generation

Each device gets its own TLS client certificate, which acts like a unique ID badge proving that this specific device is allowed to connect. Certificates are generated with the project script generate_client_certs.py, run as:

```
python generate_client_certs.py --device-id HYDROLOGIC-[Location]-[NNN]
```

The script signs the certificate with the project's Certificate Authority (CA) and embeds the device ID as the certificate's identity (Common Name). It produces a certificate (device-XXX.pem) and a private key for that device. A certificate is never shared or reused between devices.

Who has access to the CA private key: Only authorized HYDROLOGIC security engineers. The CA private key is stored encrypted and offline (not on the hotel network, not on the devices, and not in source control), and every use of it is logged. Hotel staff do not have access to it. If the key were ever exposed, every certificate it signed would have to be treated as untrusted.

Step 3: Certificate Installation

The certificate and the device's private key are installed while the technician is physically at the device, or while the device is connected to a trusted provisioning laptop before it goes into the mechanical room. The files are copied over a secure channel (USB provisioning drive or a direct wired connection). Certificates are never sent by email or chat, and remote installation over the hotel's general network is not permitted.

Two-person verification: Technician A installs the certificate. Technician B independently confirms that the certificate's unique fingerprint (thumbprint) on the device matches the fingerprint recorded in the Device Registry, and that the device ID inside the certificate matches the label on the physical device. If either check fails, stop immediately, revoke the certificate, and restart from Step 2. After installation, delete all temporary copies of the private key from the provisioning drive or laptop.

Step 4: Connection Verification

Connect the device to the hotel network and verify the following within 10 minutes:

- **Encrypted connection:** the device connects to the MQTT broker on port 8883 using mutual TLS (the broker checks the device's certificate, and the device checks the broker's).
- **Data flow:** the device publishes sensor readings on its assigned MQTT topic and the readings appear on the monitoring dashboard within 60 seconds.
- **Test messages:** send 10 test messages and confirm all 10 are received by the broker and displayed on the dashboard.

What the broker must reject: (1) any unencrypted connection on port 1883; (2) a connection with no client certificate; (3) a certificate not signed by the project CA; (4) an expired or revoked certificate; and (5) a device publishing to a topic that belongs to a different device. Run at least one negative test (for example, an attempted connection on port 1883) and confirm it is refused. If any check fails, disconnect the device and troubleshoot before leaving it in service.

Step 5: Documentation

Update the Device Registry with: device ID, physical location, certificate fingerprint, certificate expiration date, provisioning date, and the names of both technicians. Update the hotel's asset inventory to match.

Who to notify: the HYDROLOGIC senior security engineer (Maya Chen) and the hotel's facilities/engineering lead responsible for the area, so they know a new device is live and where it is. Notify the General Manager (Marcus Webb) when a batch of devices is added.

Estimated time for full onboarding: 30 minutes per device (about 10 minutes for registration and certificate generation, 10 for installation and fingerprint verification, and 10 for connection testing and documentation).

3. Certificate Rotation Schedule

Current certificate validity period: 1 year

Rotation Schedule:

- **Scheduled rotation:** start rotation 30 days before each certificate expires.
- **Expiration alerts:** automated email reminders at 30, 14, and 7 days before expiration, sent to HYDROLOGIC Security Engineering and the hotel's facilities/engineering lead.
- **Manual rotation triggered by:** any suspected compromise, loss or theft of a device, exposure of a private key, or a change in the CA or TLS configuration that requires new certificates.

Rotation Procedure

1. **Generate:** HYDROLOGIC Security Engineering generates a new certificate and a new private key (fresh keys, not the old ones) for the same device ID using generate_client_certs.py.
2. **Schedule:** book a maintenance window during low-activity hours (for example, 2:00–4:00 AM) and tell the hotel's facilities/engineering lead at least 24 hours in advance, since monitoring for that device will briefly pause.
3. **Install:** install the new certificate on the device on site, using the same two-person fingerprint verification as Section 2, Step 3.
4. **Verify:** confirm the device reconnects on port 8883 within 60 seconds and readings resume on the dashboard.
5. **Revoke the old certificate:** only after the new one is confirmed working, add the old certificate to the revocation list so it can never be used again.
6. **Record:** update the Device Registry with the new fingerprint and expiration date.

Who is responsible: HYDROLOGIC Security Engineering (Maya Chen's team) is responsible for triggering and carrying out rotation. The hotel's facilities/engineering lead is the backup for coordinating on-site access and the maintenance window.

Important: A device must never run with an expired certificate. If rotation cannot be finished before expiration, notify the General Manager and use manual water-system checks for that location until a valid certificate is installed.

4. Compromised Device Procedure

If a device is suspected to be compromised — for example, someone reports that HYDROLOGIC-PoolSpa-002 (device-002) is behaving strangely, such as sending odd readings, sending data at unusual times, or dropping offline repeatedly:

IMMEDIATE ACTIONS (within 15 minutes)

1. **Revoke the certificate.** Add device-002.pem to the revocation list so the broker refuses any future connection from that device, even if an attacker still has it.
2. **Disconnect the device.** Unplug the network cable or disable its wireless connection. Do not simply power it off, since a compromised device could reconnect on reboot. Keep the device in place and untouched for the investigation.
3. **Notify stakeholders.** Call the HYDROLOGIC senior security engineer (Maya Chen) and the hotel's facilities/engineering lead, then inform the General Manager (Marcus Webb). Because the pool pump house is no longer monitored, staff must check pool chemistry and equipment readings manually (for example, every 2 hours) until monitoring is restored.

INVESTIGATION (within 24 hours)

1. **Review logs.** Examine broker logs for the affected device: connections from unusual addresses, failed or repeated connection attempts, connections on port 1883, unexpected message patterns or timing, and any attempts to publish to other devices' topics. Compare against the device's normal behavior.
2. **Assess exposure.** Determine what the device could see and do: which topics it could publish or read, whether other devices or hotel systems were reachable from it, and whether any guest or staff data was involved. Check whether the other certificates need rotating, especially if the CA key may have been affected. Report findings to the General Manager and record the incident.

RECOVERY

1. **Factory reset** the device to remove any compromised firmware, stored credentials, or configuration.
2. **Issue a completely new certificate** with fresh keys (never reuse the old keys) and re-provision following Section 2, Steps 2–5.
3. **Verify reconnection** on port 8883 with all Step 4 checks passing, and confirm readings appear on the dashboard.
4. **Monitor closely** the device's network activity for 48 hours and flag any anomalies for immediate review.

Emergency contacts

- **HYDROLOGIC Security:** Maya Chen, Senior Security Engineer — Phone/Email: [insert 24/7 contact]
- **The Grand Marina Hotel:** Marcus Webb, General Manager — Phone: [insert]

5. Decommissioning Process

When a device is removed from service — because The Grand Marina closes a building or replaces a device:

Step 1: Revoke Certificate

Revoke the device's certificate immediately, even when the device is simply being retired and not compromised. Add it to the revocation list so the broker will never accept it again. A revoked certificate must never be reused, even if the same device ID is assigned to a replacement unit later; the replacement gets a brand-new certificate.

Step 2: Remove from Monitoring

Remove the device from the broker's list of authorized devices. Remove it from the monitoring dashboard and from alert rules, so nobody receives "device offline" or "no data" alerts for equipment that no longer exists. Confirm the dashboard shows no warnings for the retired device.

Step 3: Physical Removal

Factory reset the device to erase all certificates, private keys, and configuration. Then handle the hardware in one of two ways: (a) if it is reusable, return it to HYDROLOGIC inventory for refurbishment, and re-provision it later as a new device with a new certificate; or (b) if it is at end of life or damaged,

destroy it securely and keep a certificate of destruction. If a whole building is closing, apply this process to every device in that building.

Step 4: Documentation

Update the Device Registry to mark the device "Decommissioned," with the decommission date, reason, and technician name. Update the hotel's asset inventory to match, and update the Devices Covered table in Section 1. Archive the device's network activity logs for 90 days for audit purposes. Notify the General Manager that the device has been retired.

6. Policy Review

This policy will be reviewed:

- **Annually**
- **After any security incident** (including any compromised or suspicious device)
- **When new devices are added** (new rooms, buildings, or expansions to the water system)
- **Other:** when a building closes or is renovated, or when the CA, TLS settings, or MQTT broker configuration changes.

Next review date: September 28, 2027

Signatures

Role	Signature	Date
Prepared by: Emad Samara	Emad Samara	September 28, 2026
Reviewed by: Maya Chen, Senior Security Engineer		
Approved by: Marcus Webb, General Manager, The Grand Marina Hotel		